

ENDPOINT COMPLIANCE PROGRAM IMPLEMENTATION

Microsoft Intune - Device Compliance & Security Hardening

M365 Security Portfolio - Project 2

Prepared by	Kapil Chaudhary - GRC & Cybersecurity Professional
Date	September 2026
Platform	Microsoft Intune (M365 E5 Trial Environment)
Framework Alignment	ISO 27001:2022, SOC 2, PCI DSS, NIST CSF
Prerequisite	Project 1- IAM Framework (Entra ID) - Completed
GitHub	github.com/ethicalkaps

Executive Summary

This document presents a complete Endpoint Compliance Program implemented in Microsoft Intune within a Microsoft 365 E5 environment. The project demonstrates hands-on capability in designing and configuring tiered device compliance policies, security hardening configuration profiles, and endpoint security controls - ensuring every device accessing corporate resources meets the organization's security baseline.

The compliance program follows a risk-based, tiered approach: a baseline policy for all devices, a protection-focused policy for firewall and antivirus enforcement, and an enhanced policy with stricter requirements for privileged users.

This project directly connects to Project 1 (IAM Framework) - the Conditional Access policy CA-003 (Require Compliant Device for Finance) depends on Intune compliance policies to determine whether a device meets the security standard.

All configurations were performed in a personal M365 E5 trial environment for portfolio demonstration purposes. No production systems or employer data were used. Compliance policies are configured and assigned; device enrollment pending for production compliance evaluation.

Compliance Mapping Overview

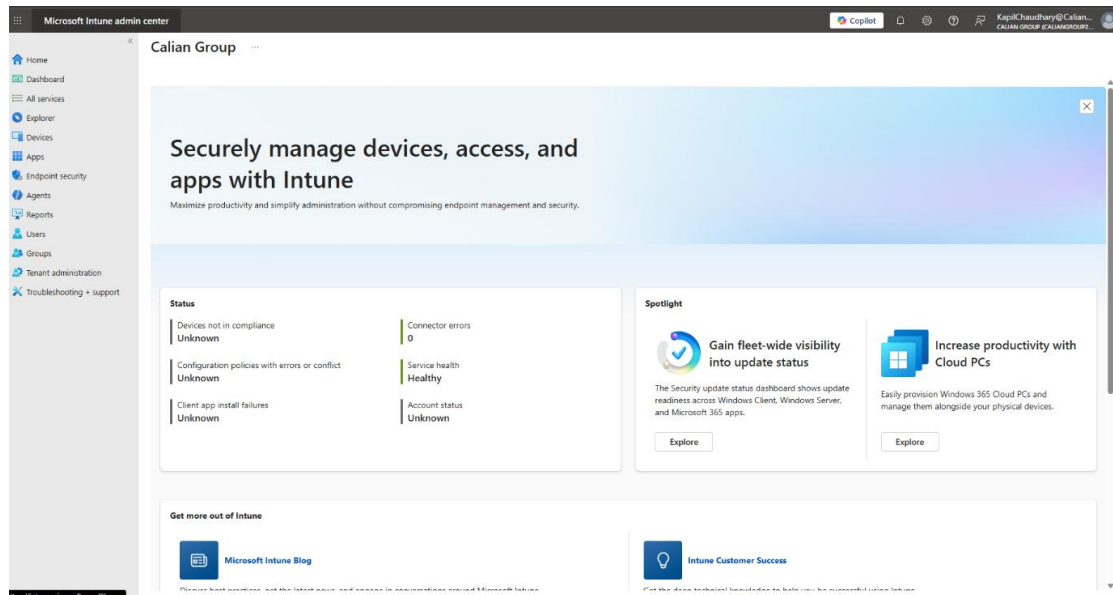
Each compliance policy and configuration maps to specific framework controls. The following table provides a summary of all compliance mappings covered in this implementation.

Configuration	ISO 27001 Control	SOC 2 / PCI DSS
CP-001: BitLocker encryption required	A.8.24 - Use of cryptography	SOC 2 CC6.1 / PCI DSS Req 3
CP-001: Secure Boot required	A.8.8 - Technical vulnerability mgmt	SOC 2 CC6.8
CP-001: Minimum OS version	A.8.8 - Technical vulnerability mgmt	PCI DSS Req 6 - Secure systems
CP-001: Password requirements	A.9.4.3 - Password mgmt system	SOC 2 CC6.1 / PCI DSS Req 8
CP-002: Firewall required	A.13.1.1 - Network controls	SOC 2 CC6.6 / PCI DSS Req 1
CP-002: Antivirus/antimalware required	A.12.2.1 - Controls against malware	SOC 2 CC6.8 / PCI DSS Req 5
CP-002: Defender definitions up-to-date	A.12.2.1 - Controls against malware	PCI DSS Req 5
CP-003: Enhanced password (12 char)	A.9.4.3 - Password mgmt system	PCI DSS Req 8
CP-003: TPM required	A.8.24 - Use of cryptography	SOC 2 CC6.1
CP-003: Auto-retire after 14 days	A.8.8 - Vulnerability mgmt	SOC 2 CC7.4 - Incident response
CFG-001: Block simple passwords	A.9.4.3 - Password mgmt system	PCI DSS Req 8
CFG-001: Screen lock timeout	A.11.2.8 - Unattended equipment	SOC 2 CC6.1
CFG-001: Require encryption	A.8.24 - Use of cryptography	PCI DSS Req 3

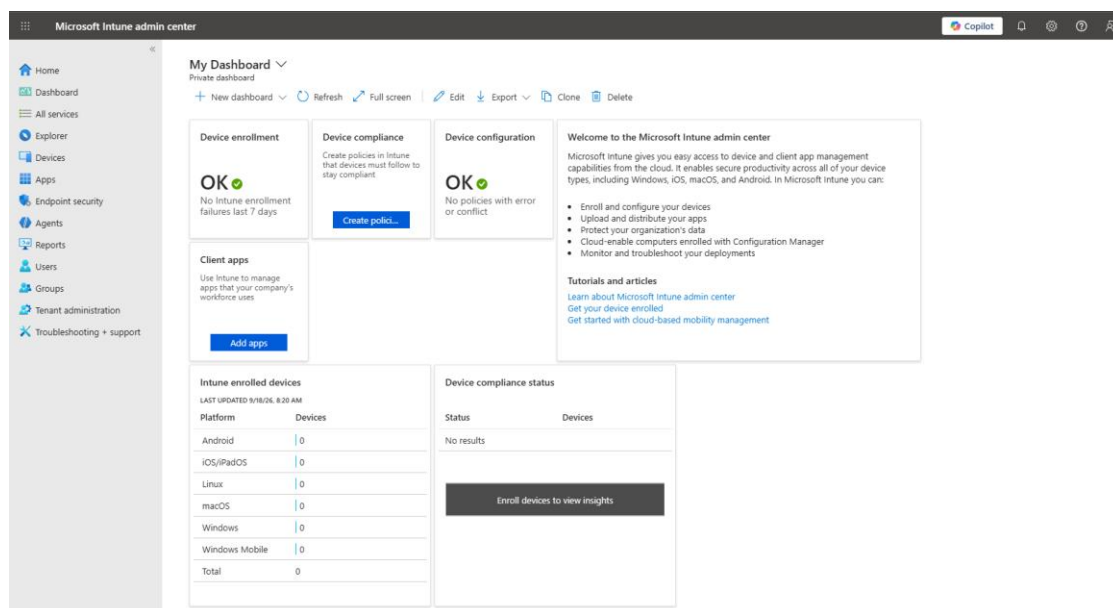
1. Environment Overview

Microsoft Intune is the cloud-based endpoint management platform within the Microsoft 365 ecosystem. It provides Mobile Device Management (MDM) for enrolling and managing devices, and Mobile Application Management (MAM) for protecting corporate data at the application level. In a compliance context, Intune is the enforcement mechanism - it defines what 'compliant' means, evaluates devices against that definition, and reports the results to Entra ID for Conditional Access policy enforcement.

1.1 Intune Home Dashboard

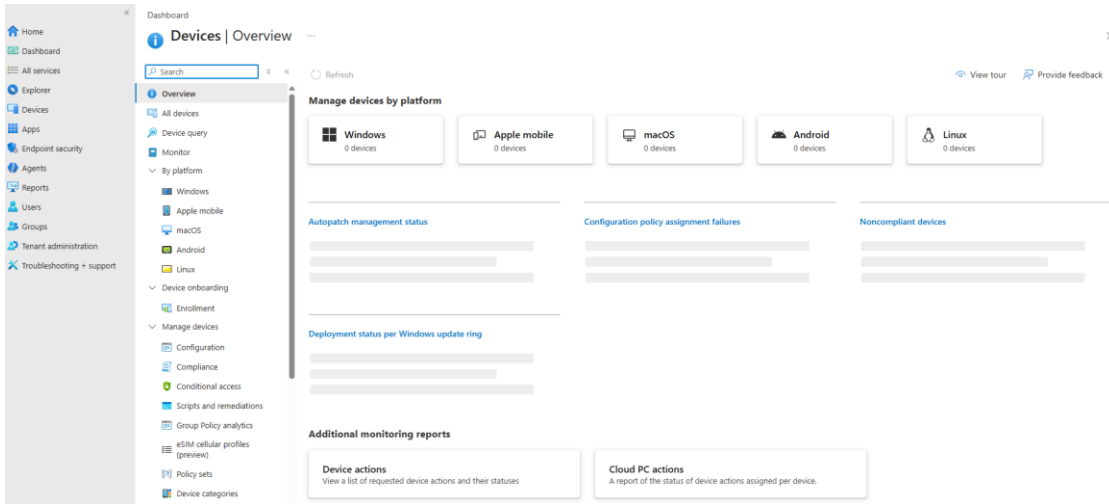


1.2 Dashboard Overview

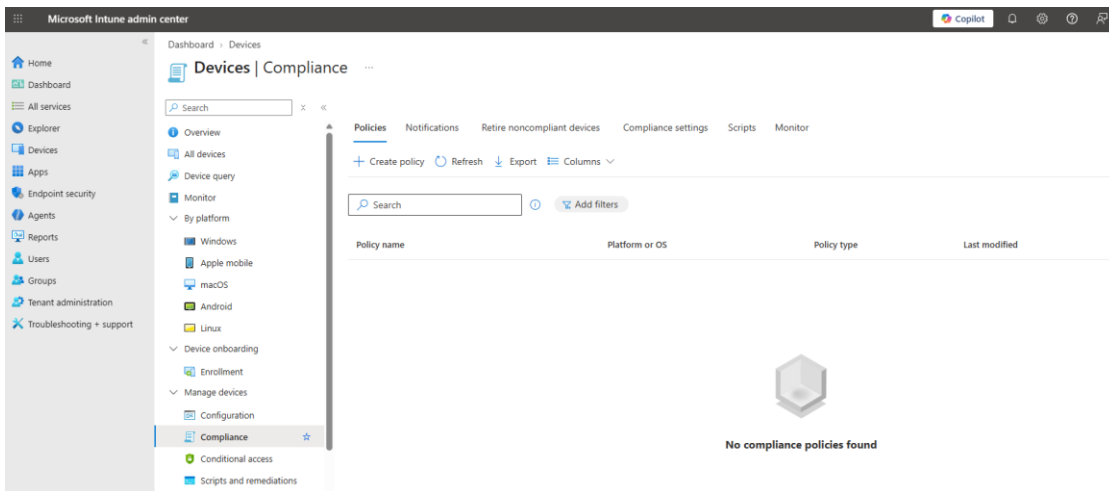


1.3 Devices Overview

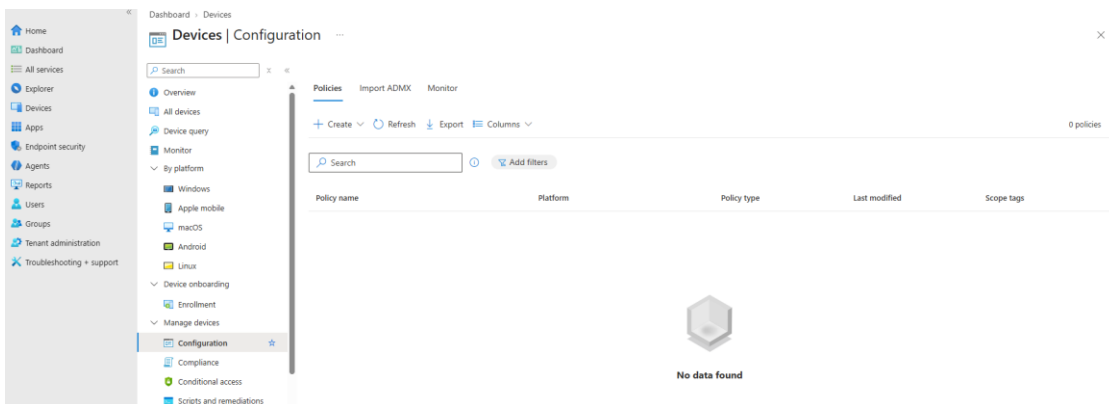
The Devices Overview shows enrolled device count, compliance status distribution, and platform breakdown. In a production environment, this dashboard provides the at-a-glance compliance posture that leadership reviews.



1.4 Compliance Policies Overview

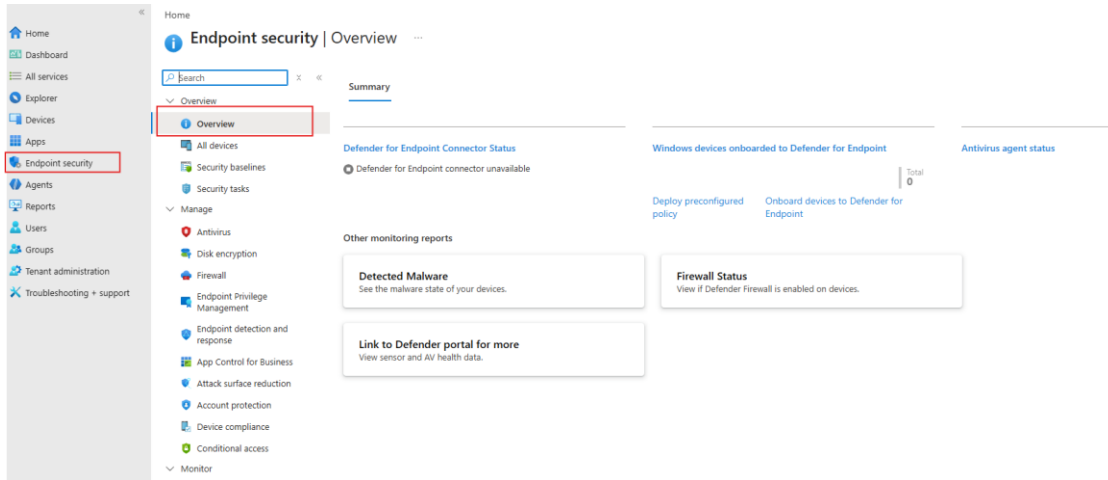


1.5 Configuration Profiles Overview



1.6 Endpoint Security Overview

Endpoint Security provides dedicated management for antivirus, firewall, disk encryption, and attack surface reduction policies - offering deeper security controls beyond the baseline compliance policies.

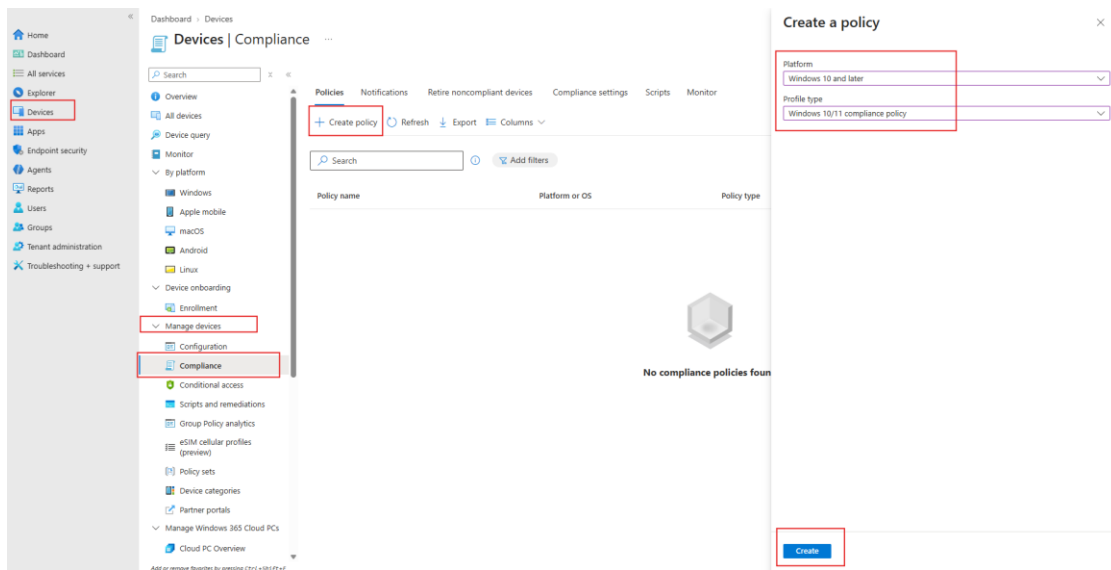


2. Compliance Policies - Tiered Approach

Three compliance policies were designed following a tiered, risk-based approach. A baseline policy applies to all devices establishing minimum security standards. A protection policy ensures active firewall and antivirus coverage. An enhanced policy applies stricter requirements to devices used by privileged users. This tiered model is how enterprise organizations manage endpoint compliance proportionally - not one-size-fits-all, but controls scaled to the risk level of the user.

2.1 CP-001: Windows Security Baseline

The baseline compliance policy establishes the minimum acceptable security standard for every Windows device accessing corporate resources. Requirements include BitLocker encryption, Secure Boot, minimum OS version (Windows 10 22H2), password requirements (minimum 10 characters), and 5-minute inactivity lock. Non-compliant devices are marked immediately with user notification after 24 hours.



Microsoft Intune admin center

Home

Dashboard

All services

Explorer

Devices

Apps

Endpoint security

Agents

Reports

Users

Groups

Tenant administration

Troubleshooting + support

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

1 Basics

2 Compliance settings

3 Actions for noncompliance

4 Assignments

5 Review + create

Name *

CP-001: Windows Security Baseline

Description

Minimum security standard every device must meet.

Platform

Windows 10 and later

Profile type

Windows 10/11 compliance policy

Home

Dashboard

All services

Explorer

Devices

Apps

Endpoint security

Agents

Reports

Users

Groups

Tenant administration

Troubleshooting + support

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

1 Basics

2 Compliance settings

3 Actions for noncompliance

4 Assignments

5 Review + create

Custom Compliance

Device Health

Microsoft Attestation Service evaluation settings

Use these settings to confirm that a device has protective measures enabled at boot time. [Learn more](#)

Windows 10 and 11

BitLocker

Require

Not configured

Secure Boot

Require

Not configured

Code integrity

Require

Not configured

Device Properties

Operating System Version

Minimum OS version

10.0.19045

Maximum OS version

Not configured

Minimum OS version for mobile devices

Not configured

Maximum OS version for mobile devices

Not configured

Valid operating system builds

Not configured

Not configured

Not configured

Export

Previous

Next

Microsoft Intune admin center

Home

Dashboard

All services

Explorer

Devices

Apps

Endpoint security

Agents

Reports

Users

Groups

Tenant administration

Troubleshooting + support

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

System Security

Password

Require a password to unlock mobile devices

Require

Not configured

Simple passwords

Block

Not configured

Password type

Device default

Minimum password length

10

Maximum minutes of inactivity before password is required

5 minutes

Password expiration (days)

41

Number of previous passwords to prevent reuse

5

Require password when device returns from idle state (Mobile and Holographic)

Require

Not configured

Encryption

Require encryption of data storage on device

Require

Not configured

Device Security

Firewall

Require

Not configured

Trusted Platform Module (TPM)

Require

Not configured

Antivirus

Require

Not configured

Previous

Next

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Basics

Compliance settings

Actions for noncompliance

Assignments

Review + create

Specify the sequence of actions on noncompliant devices

Action	Schedule (days after noncompliance)	Message template	Additional recipients (...)
Mark device noncompliant	Immediately		
	0		

Microsoft Intune admin center

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Basics

Compliance settings

Actions for noncompliance

Assignments

Review + create

Included groups

Add groups

Add all users

Add all devices

Groups	Status	Group Members	Filter	Filter mode	Edit filter	Remove
All users	Active		None	None	Edit filter	Remove

Excluded groups

When excluding groups, you cannot mix user and device groups across include and exclude. [Click here to learn more about excluding groups.](#)

Add groups

Groups	Status	Group Members	Remove
No groups selected			

Microsoft Intune admin center

Home

Dashboard

All services

Explorer

Devices

Apps

Endpoint security

Agents

Reports

Users

Groups

Tenant administration

Troubleshooting + support

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Basics

Compliance settings

Actions for noncompliance

Assignments

Review + create

Summary

Basics

Name

CP-001: Windows Security Baseline

Description

Minimum security standard every device must meet.

Platform

Windows 10 and later

Profile type

Windows 10/11 compliance policy

Compliance settings

Device Health

BitLocker

Require

Secure Boot

Require

Device Properties

Minimum OS version

10.0.19045

System Security

Require a password to unlock mobile devices

Require

Minimum password length

10

Maximum minutes of inactivity before password is required

5 minutes

Require encryption of data storage on device.

Require

Actions for noncompliance

Action

Schedule

Message template

Additional recipients (via ...)

Previous

Create

ISO 27001: A.8.24 (Cryptography), A.8.8 (Vulnerability Mgmt), A.9.4.3 (Password Mgmt). PCI DSS: Req 3, 6, 8. SOC 2: CC6.1.

2.2 CP-002: Firewall and Antivirus Required

This policy ensures every device has active protection against network threats and malware. Requirements include Windows Firewall enabled, antivirus active, antispysware active, Microsoft Defender Antimalware running, and Defender security intelligence definitions up-to-date. Devices failing any of these checks are marked noncompliant immediately.

Microsoft Intune admin center

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Require password when device returns from idle state (Mobile and Holographic)

RequireNot configured

Encryption

Require encryption of data storage on device.

RequireNot configured

Device Security

Firewall

RequireNot configured

Trusted Platform Module (TPM)

RequireNot configured

Antivirus

RequireNot configured

Antispyware

RequireNot configured

Defender

Microsoft Defender Antimalware

RequireNot configured

Microsoft Defender Antimalware minimum version

Not configured

Microsoft Defender Antimalware security intelligence up-to-date

RequireNot configured

Real-time protection

RequireNot configured

Microsoft Defender for Endpoint

Windows Subsystem for Linux (WSL)

Previous

Next

Microsoft Intune admin center

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Basics

Compliance settings

Actions for noncompliance

Assignments

Review + create

Specify the sequence of actions on noncompliant devices

Action	Schedule (days after noncompliance)	Message template	Additional recipients (...)
Mark device noncompliant	Immediately		
	0		

Microsoft Intune admin center

Copilot

Home

Dashboard

All services

Explorer

Devices

Apps

Endpoint security

Agents

Reports

Users

Groups

Tenant administration

Troubleshooting + support

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Basics

Compliance settings

Actions for noncompliance

Assignments

Review + create

Included groups

Add groups

Add all users

Add all devices

Groups	Status	Group Members	Filter	Filter mode	Edit filter	Remove
All users	Active		None	None	Edit filter	Remove

Excluded groups

When excluding groups, you cannot mix user and device groups across include and exclude. [Click here to learn more about excluding groups.](#)

Add groups

Groups	Status	Group Members	Remove
No groups selected			

Microsoft Intune admin center

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Basics

Compliance settings

Actions for noncompliance

Assignments

Review + create

Summary

Basics

NameCP-002: Firewall and Antivirus Required

DescriptionNo Description

PlatformWindows 10 and later

Profile typeWindows 10/11 compliance policy

Compliance settings

System Security

Firewall	Require
Antivirus	Require
Antispyware	Require
Microsoft Defender Antimalware	Require
Microsoft Defender Antimalware security intelligence up-to-date	Require

Actions for noncompliance

Action	Schedule	Message template	Additional recipients (via ...)
Mark device noncompliant	Immediately		

Assignments

Included groups

Group	Status	Group Members	Filter
All users	Active		None

ISO 27001: A.13.1.1 (Network Controls), A.12.2.1 (Malware Controls). PCI DSS: Req 1, 5. SOC 2: CC6.6, CC6.8.

2.3 CP-003: Enhanced Compliance - Privileged Devices

This policy applies exclusively to the SG-Privileged-Users group - IT Administrators and Cloud Engineers whose devices have access to production systems and sensitive infrastructure. Requirements are stricter than baseline: 12-character alphanumeric passwords, 3-minute inactivity lock, TPM required, code integrity required, and all baseline requirements. The critical differentiator is the noncompliance action: devices that remain noncompliant for 14 days are automatically retired (wiped), ensuring that privileged access devices cannot persist in a vulnerable state.

Microsoft Intune admin center

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

1 Basics2 Compliance settings3 Actions for noncompliance4 Assignments5 Review + create

Name *

CP-003: Enhanced Compliance — Privileged Devices

Description

This policy applies ONLY to your SG-Privileged-Users group - stricter requirements for devices used by admins and engineers.

Platform

Windows 10 and later

Profile type

Windows 10/11 compliance policy

Microsoft Intune admin center

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

1 Basics2 Compliance settings3 Actions for noncompliance4 Assignments5 Review + create

Custom Compliance

Device Health

Microsoft Attestation Service evaluation settings

Use these settings to confirm that a device has protective measures enabled at boot time. [Learn more](#)

Windows 10 and 11

BitLocker

Require

Not configured

Secure Boot

Require

Not configured

Code integrity

Require

Not configured

Device Properties

Configuration Manager Compliance

System Security

Microsoft Defender for Endpoint

Windows Subsystem for Linux (WSL)

Microsoft Intune admin center

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Home

Dashboard

All services

Explorer

Devices

Apps

Endpoint security

Agents

Reports

Users

Groups

Tenant administration

Troubleshooting + support

System Security

Password

Require a password to unlock mobile devices

Require

Not configured

Simple passwords

Block

Not configured

Password type

Alphanumeric

Password Complexity

Require digits, lowercase, uppercase, and special characters

Minimum password length

12

Maximum minutes of inactivity before password is required

5 minutes

Password expiration (days)

41

Number of previous passwords to prevent reuse

5

Require password when device returns from idle state (Mobile and Holographic)

Require

Not configured

Encryption

Require encryption of data storage on device

Require

Not configured

Device Security

Firewall

Require

Not configured

Trusted Platform Module (TPM)

Require

Not configured

Previous

Next

Microsoft Intune admin center

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Home

Dashboard

All services

Explorer

Devices

Apps

Endpoint security

Agents

Reports

Users

Groups

Tenant administration

Troubleshooting + support

Basics

Compliance settings

Actions for noncompliance

Assignments

Review + create

Specify the sequence of actions on noncompliant devices

Action	Schedule (days after noncompliance)	Message template	Additional recipients (...)
Mark device noncompliant	Immediately		
Add device to retire l...	14		...
	0		

Home

Dashboard

All services

Explorer

Devices

Apps

Endpoint security

Agents

Reports

Users

Groups

Tenant administration

Troubleshooting + support

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Basics

Compliance settings

Actions for noncompliance

Included groups

Add all users

Add all devices

Groups

Status

Group Member

No groups selected

Excluded groups

When excluding groups, you cannot mix user and device groups across include and exclude.

Add groups

Groups

Status

Group Member

No groups selected

Previous

Next

Select groups to include

Azure AD Groups

Try changing or adding filters if you don't see what you're looking for.

Search

3 results found

Groups

☐

SG-IT-Department

☒

SG-Privileged-Users

☐

SG-Standard-Users

Selected (1)

Reset

SG-Privileged-Users

Select

Microsoft Intune admin center

Home

Dashboard

All services

Explorer

Devices

Apps

Endpoint security

Agents

Reports

Users

Groups

Tenant administration

Troubleshooting + support

Dashboard > Devices | Compliance

Windows 10/11 compliance policy

Windows 10 and later

Basics

Compliance settings

Actions for noncompliance

Assignments

Review + create

Summary

Basics

Name

CP-003: Enhanced Compliance — Privileged Devices

Description

This policy applies ONLY to your SG-Privileged-Users group - stricter requirements for devices used by admins and engineers.

Platform

Windows 10 and later

Profile type

Windows 10/11 compliance policy

Compliance settings

Device Health

BitLocker

Require

Secure Boot

Require

Code integrity

Require

System Security

Require a password to unlock mobile devices

Require

Password type

Alphanumeric

Password Complexity

Require digits, lowercase, uppercase, and special characters

Minimum password length

12

Maximum minutes of inactivity before password is required

5 minutes

Require encryption of data storage on device.

Require

Firewall

Require

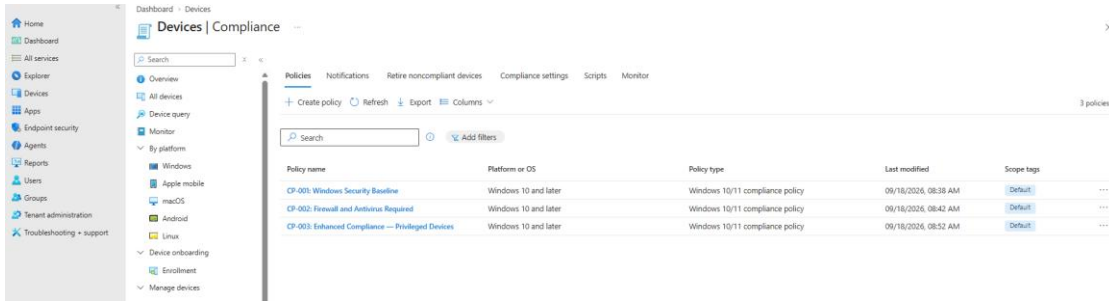
Trusted Platform Module (TPM)

Require

Actions for noncompliance

Previous

Create



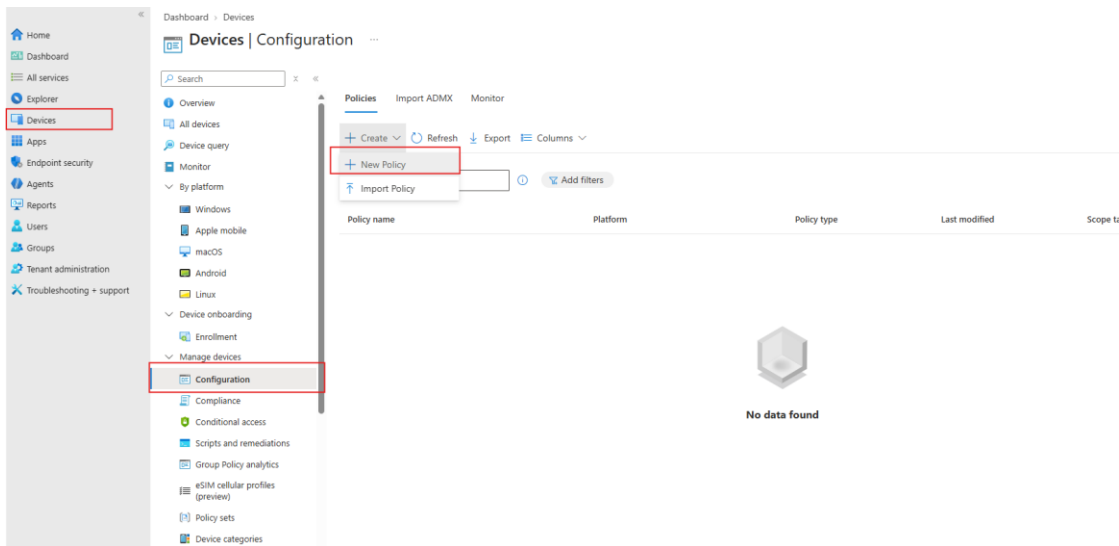
ISO 27001: A.9.2.3 (Privileged Access Mgmt), A.9.4.3 (Password Mgmt). PCI DSS: Req 7, 8. SOC 2: CC6.1.

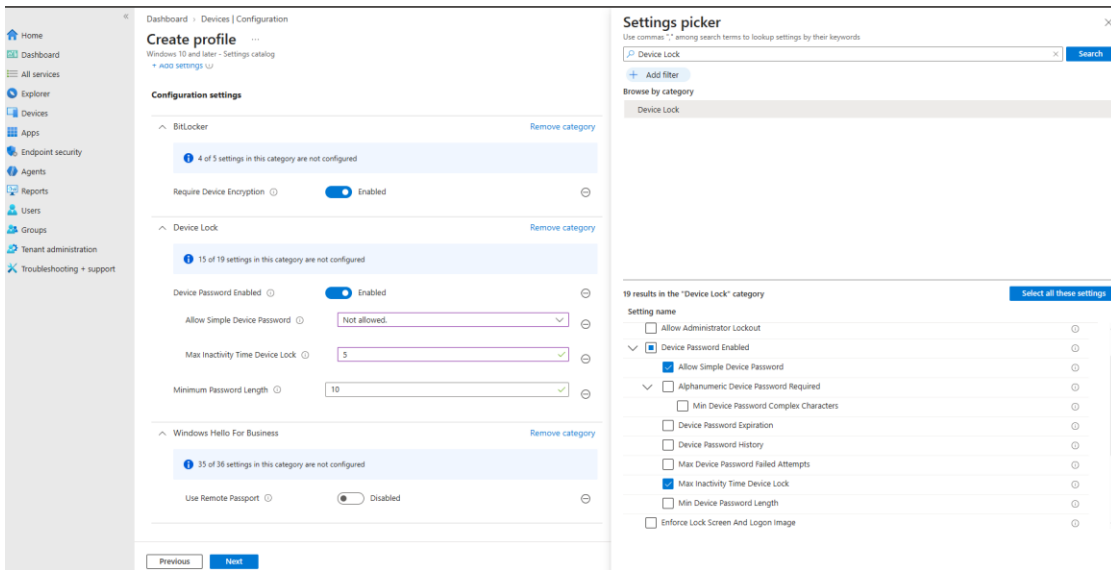
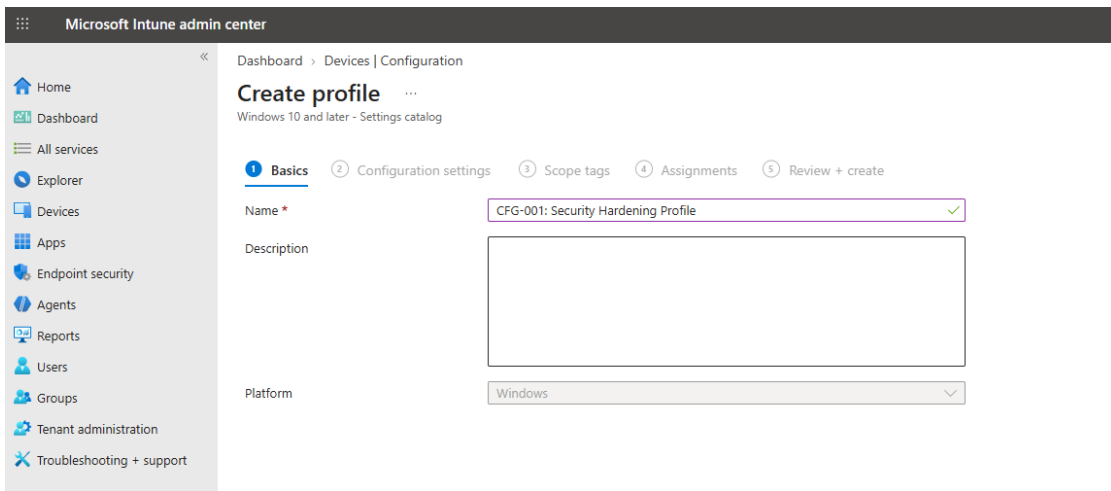
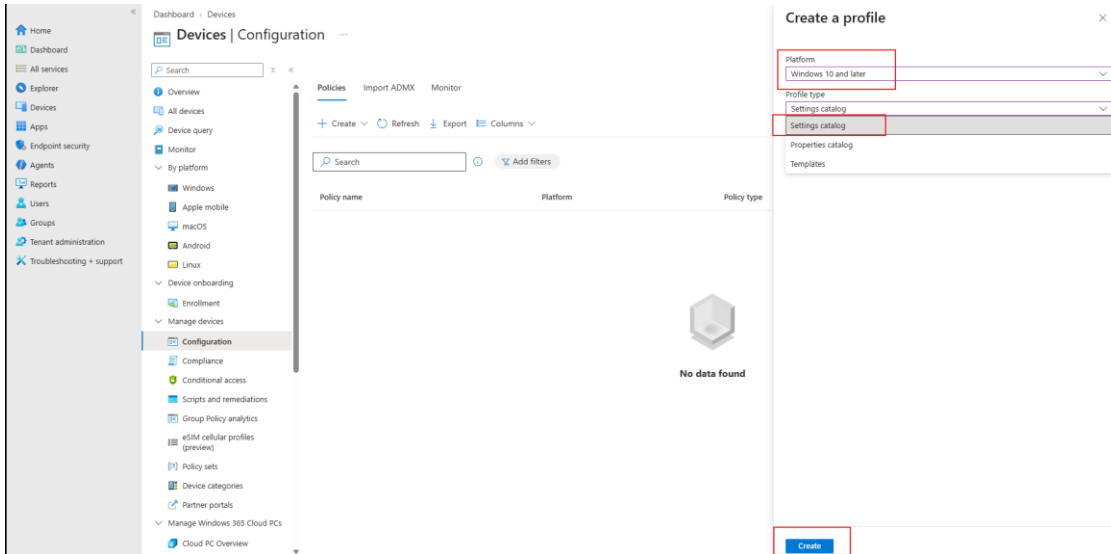
3. Configuration Profile - Security Hardening

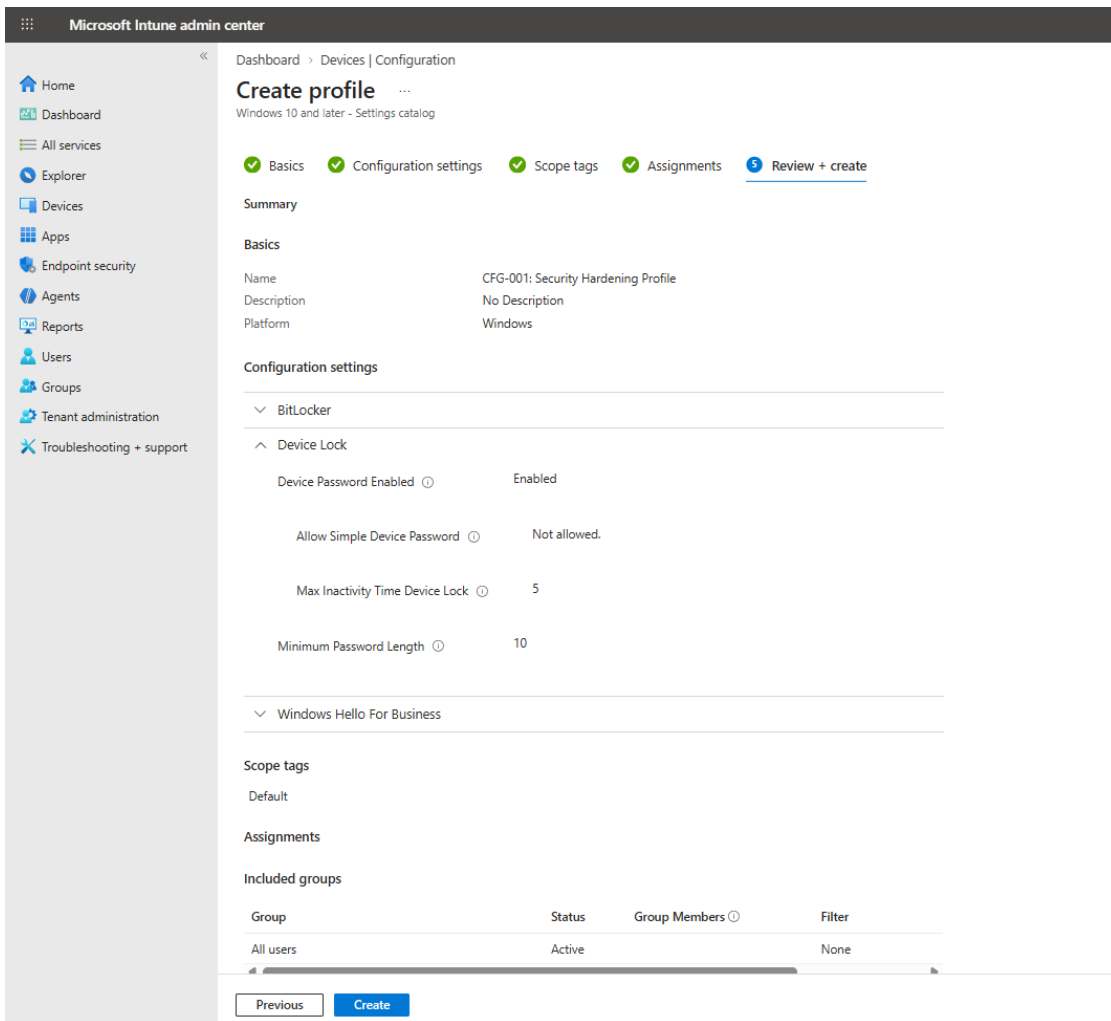
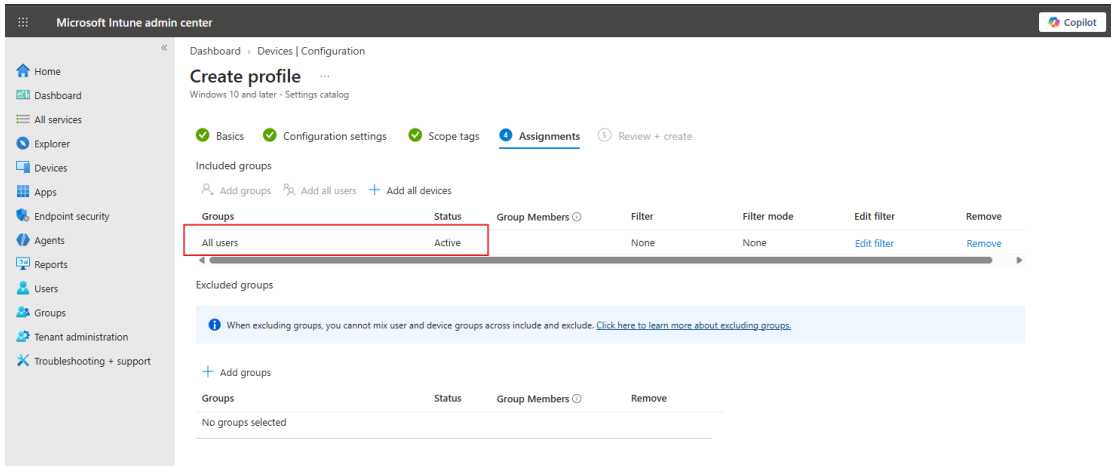
Compliance policies check whether a device meets standards. Configuration profiles push settings to devices to help them meet those standards. Both are needed - compliance without configuration means devices are flagged but not helped; configuration without compliance means settings are pushed but never verified.

3.1 CFG-001: Security Hardening Profile

A Settings Catalog-based configuration profile was created to push security hardening settings to all enrolled devices. Settings include: Windows Hello for Business disabled (forcing traditional MFA instead), device encryption required, simple passwords blocked, minimum password length of 10 characters, and 5-minute screen lock timeout. Each setting was searched individually in the Settings Catalog and configured with specific values.





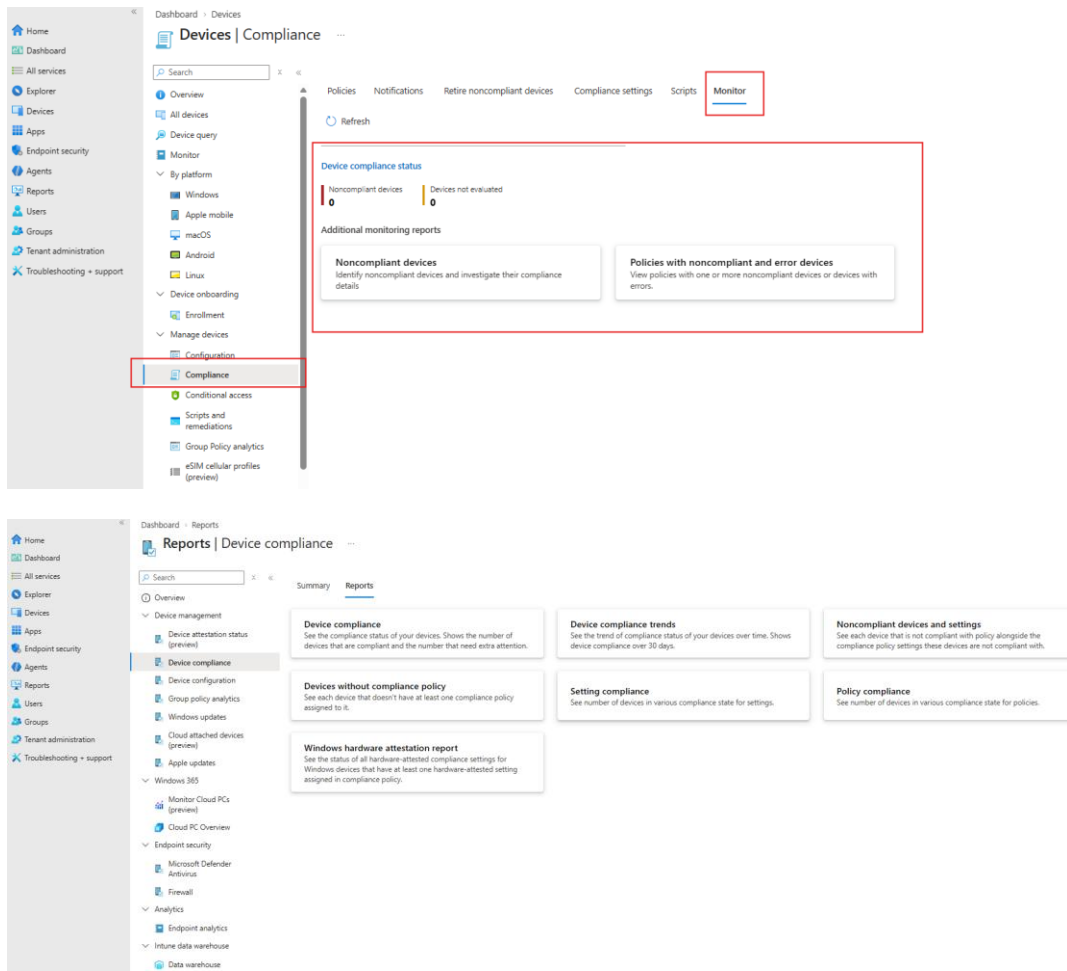


Technical Note: The Settings Catalog provides granular control over thousands of individual Windows policy settings - searchable by keyword. This is how enterprise administrators push specific security hardening configurations that go beyond basic compliance baselines. Each setting was located using its technical name (e.g., 'Allow Simple Password', 'Min Device Password Length', 'Max Inactivity Time Device Lock').

ISO 27001: A.9.4.3 (Password Mgmt), A.11.2.8 (Unattended Equipment), A.8.24 (Cryptography). SOC 2: CC6.1.

4. Compliance Monitoring and Reporting

Intune provides built-in compliance monitoring dashboards that track device compliance status in real-time. In a production environment, these dashboards show compliant vs. noncompliant device counts, compliance trends over time, and per-policy compliance rates - the data that feeds into GRC reporting for leadership and audit evidence for external assessors.



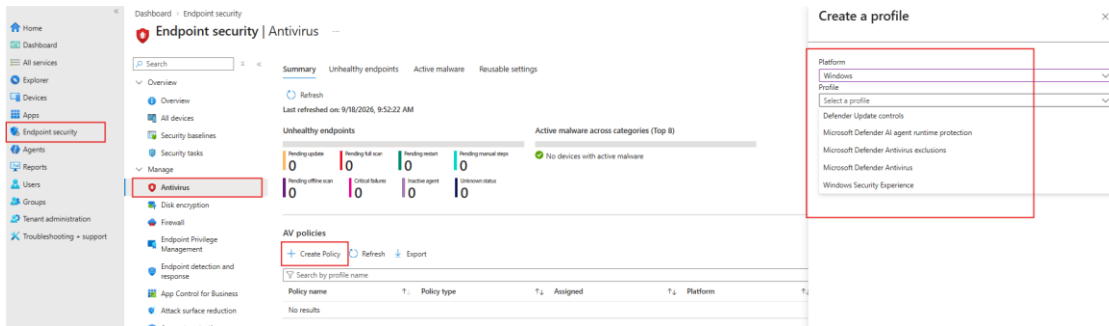
Production Note: Compliance policies are configured, assigned, and ready for enforcement. Device enrollment pending for production compliance evaluation. In a live environment, the compliance dashboard would display real-time device compliance status against the three-tier policy baseline defined above.

5. Endpoint Security - Deep Dive

Beyond compliance policies, Intune's Endpoint Security section provides dedicated management for security-specific controls. These offer deeper configuration than compliance policies for antivirus behavior, firewall rules, disk encryption settings, and attack surface reduction.

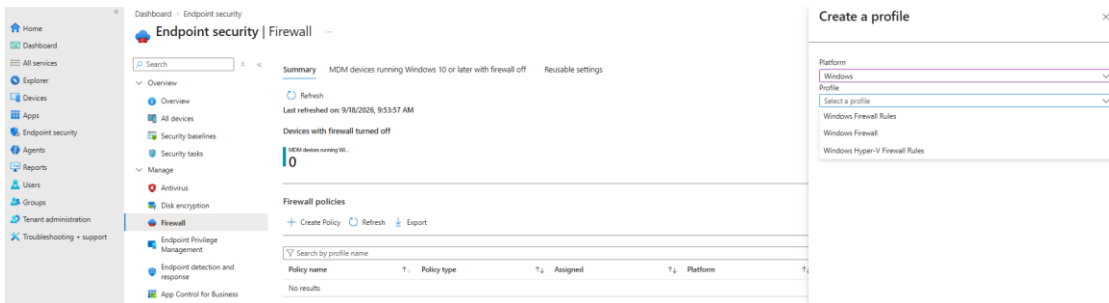
5.1 Antivirus Management

Centralized management of Microsoft Defender Antivirus policies - scan schedules, real-time protection settings, exclusions, and cloud-delivered protection configuration.



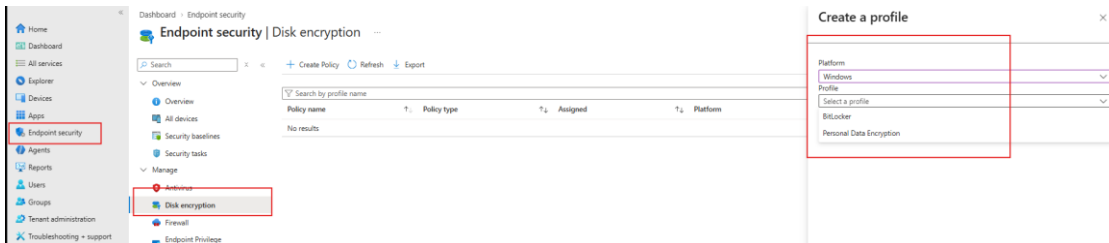
5.2 Firewall Management

Granular firewall rule management beyond the binary 'firewall required' compliance check - specific inbound/outbound rules, application-level controls, and network profile settings.



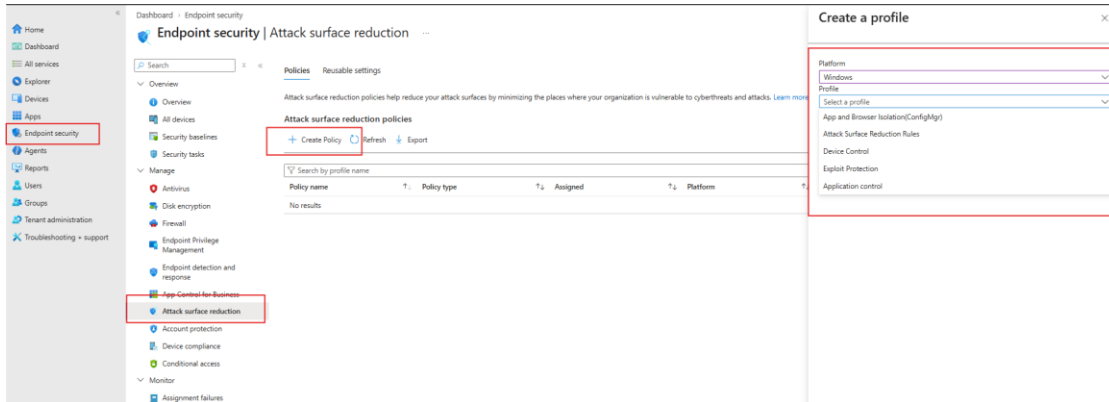
5.3 Disk Encryption (BitLocker)

BitLocker management at a deeper level than compliance policies - encryption method selection, recovery key storage, pre-boot authentication requirements, and encryption status monitoring.



5.4 Attack Surface Reduction

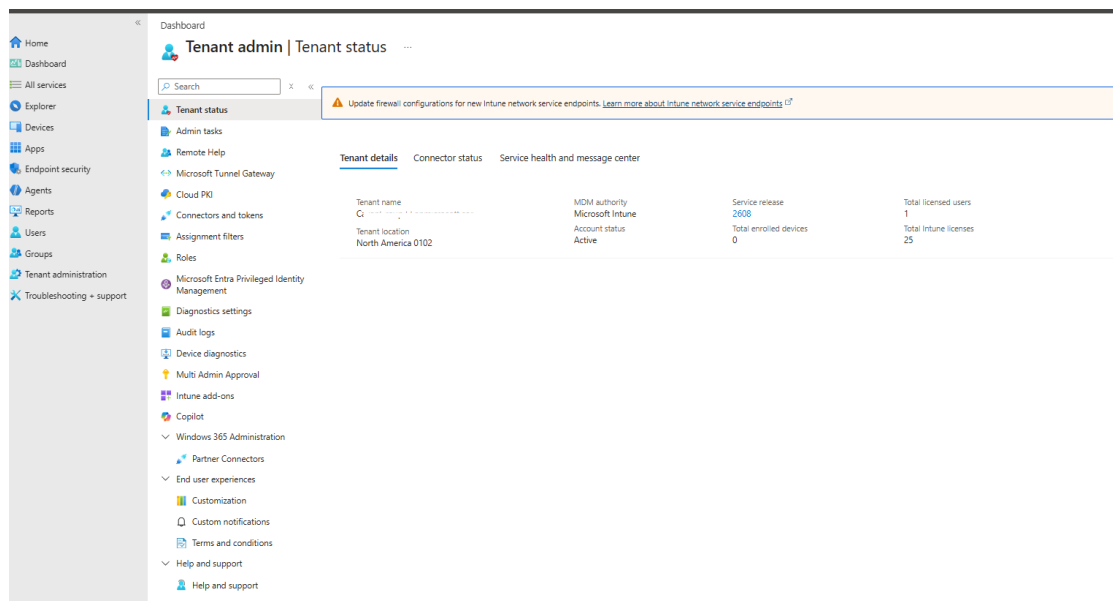
Attack Surface Reduction (ASR) rules block specific behaviors commonly exploited by malware - Office macros creating child processes, credential theft from LSASS, executable content from email attachments, and script obfuscation. These rules significantly reduce the attack surface without impacting normal user productivity.



ISO 27001: A.12.2.1 (Malware Controls), A.13.1.1 (Network Controls), A.8.24 (Cryptography). SOC 2: CC6.6, CC6.8. PCI DSS: Req 1, 5.

6. Tenant Administration - Connectors and Integration

Intune's connector architecture enables integration with external security systems - certificate authorities, threat defense partners (Microsoft Defender for Endpoint), partner compliance solutions, and SIEM platforms. This integration layer is how endpoint compliance data flows into broader GRC reporting and how organizations achieve unified security visibility across identity, endpoint, and threat management platforms.



7. Cross-Project Integration - Entra ID + Intune

This project directly connects to Project 1 (IAM Framework). The Conditional Access policy CA-003 (Require Compliant Device for Finance) created in Entra ID evaluates device compliance status from Intune before granting access. This integration demonstrates the identity-to-endpoint security chain: Entra ID controls WHO can access resources (identity), Intune controls WHAT devices meet the security standard (endpoint), and

Conditional Access ties them together - only authenticated users on compliant devices can access sensitive applications.

Additionally, the SG-Privileged-Users group created in Project 1 is reused here as the assignment target for CP-003 (Enhanced Compliance). This group-based policy targeting ensures consistent security enforcement across both identity and endpoint layers - a fundamental principle of zero-trust architecture.

Zero Trust Principle: Never trust, always verify. Verify the user (Entra ID MFA), verify the device (Intune compliance), verify the access level (Conditional Access policy), continuously monitor (Sign-in logs, Compliance dashboard).

8. Conclusion

This project demonstrates end-to-end endpoint compliance management in Microsoft Intune - from tiered compliance policy design through security hardening configuration profiles, endpoint security controls, and compliance monitoring. The three-tier compliance model (baseline, protection, enhanced) reflects enterprise best practices for managing diverse user populations with proportional security controls based on risk level.

Combined with Project 1's IAM Framework, these two projects establish the identity and endpoint security foundation of a zero-trust architecture - proving both the ability to design security controls and the understanding of how those controls map to ISO 27001, SOC 2, and PCI DSS compliance requirements.

This is Project 2 of 5 in the Microsoft Security Portfolio. Subsequent projects cover Data Classification & DLP (Purview), Security Posture Assessment (Defender + Nessus), and Incident Response Playbooks.